ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

VMware ESXi 8 (vSphere Hypervisor) · Component type: **Host Device (HDR) - bare-metal hypervisor** · Target SL = SL 3

Where to work	Manage via **vCenter** (SSO roles) or the **ESXi Host Client** (HTTPS 443); **DCUI** (console); **PowerCLI** (`Get-VMHost`, `Get-AdvancedSetting`) and **ESXCLI**. SSH / ESXi Shell are **off by default**. Baseline against the **DISA vSphere ESXi 8 STIG** + **vSphere Security Configuration Guide**.
Interfaces / ports	HTTPS **443** (API/Host Client); VMkernel **902**; **SSH 22** (disabled); vMotion 8000; vSAN; syslog 514; CIM 5989 (disable). Isolate the management VMkernel on its own VLAN.
Notes	HDR (bare-metal hypervisor). Confirm `esxcli system version get` (ESXi 8.0 Ux) and **Lockdown Mode** (Normal/Strict). Verify effective settings via PowerCLI advanced settings.
How to read	Default read-only (PowerCLI/ESXCLI get, Host Client view). Native how-to + external-tool validation + pass. Write/exploit tools = isolated env + written authorization.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.1	Human user I&A;	Management authenticated via vCenter SSO / host local accounts; **SSH & ESXi Shell disabled** (`Get-VMHostService` -> TSM/TSM-SSH Stopped, Policy off); DCUI restricted; **Lockdown Mode** enabled. **Test:** no anonymous host access; SSH refused. **Ext. tools:** PowerCLI (`Get-VMHostService`); STIG/SCAP scan; Nmap (22 closed).	All host access authenticates; SSH/Shell off; lockdown mode on.	HDR.
SR/CR 1.2	Software Process and Device Identification and Authentication	Assess per objective: Identify and authenticate all software processes and devices.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.3	Account management	Minimal local users; join to AD / use vCenter for identity; manage the root password (vault/LAPS-equivalent); remove unused local accounts. **Ext. tools:** PowerCLI/Host Client user review; STIG scan.	Named least-priv identities; root managed; no unused local accounts.	
SR/CR 1.4	Identifier Management	Confirm identifiers (user and device IDs) are unique, not reused, and managed over their lifecycle.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.5 / 1.7	Authenticator & password strength	Password quality: `Security.PasswordQualityControl` (e.g. `similar=deny retry=3 min=disabled,disabled,disabled,7,7`); password history `Security.PasswordHistory`; verify via advanced settings. **Ext. tools:** `Get-AdvancedSetting -Name Security.Password*`; STIG scan.	Strong password quality + history enforced.	
SR/CR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.8	Public Key Infrastructure (PKI) Certificates	Confirm any device/server certificates are CA-issued, valid, and revocable per PKI practice.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.9	Strength of Public Key Authentication	Confirm public-key / certificate authentication uses strong keys and algorithms (>=2048 RSA / ECC).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.10	Authenticator Feedback	Confirm authenticators (passwords) are obscured during entry (masked) on every interface.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.11	Unsuccessful login attempts	Account lockout: `Security.AccountLockFailures` (e.g. 3) + `Security.AccountUnlockTime` (e.g. 900). Verify advanced settings. **Ext. tools:** `Get-AdvancedSetting -Name Security.Account*`; STIG scan.	Lockout after few failed attempts for a set time.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.12	System use notification	Login banner: `Annotations.WelcomeMessage` (DCUI/Host Client) and `Config.Etc.issue` (SSH) set to the approved notice. **Ext. tools:** `Get-AdvancedSetting -Name Annotations.WelcomeMessage`; STIG scan.	Approved banner displayed at DCUI/Host Client/SSH.	
SR/CR 1.13	Access via untrusted networks	Isolate the management VMkernel (dedicated VLAN); Lockdown Mode; ESXi firewall restricts mgmt sources; no direct host mgmt from untrusted networks. **Ext. tools:** Nmap (443/902 reachability by segment); firewall review.	Host mgmt reachable only from the isolated mgmt network.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 2.1	Authorization enforcement	vCenter **roles/permissions** least privilege; Lockdown-Mode Exception Users minimal; DCUI.Access limited. **Test:** a low-priv vCenter role cannot change host config. **Ext. tools:** PowerCLI (`Get-VIPermission`); STIG scan.	Least privilege via roles; exception users minimal.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use Control for Portable and Mobile Devices	Assess per objective: Enforce configurable usage restrictions for portable/mobile devices.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.4	Mobile Code	Assess per objective: Enforce usage restrictions for mobile code technologies.	Met per SL-3 - verify on the product and capture evidence.	completeness
HDR 2.4	Mobile Code (Host)	Assess the HDR-specific requirement per objective: Host device shall control and restrict the use of mobile code, enforcing authorization, integrity, and execution constraints.	Met per SL-3 - verify and capture evidence.	HDR completeness
SR/CR 2.5	Session lock / timeouts	Shell/DCUI timeouts: `UserVars.ESXiShellInteractiveTimeOut`, `UserVars.ESXiShellTimeOut`, `UserVars.DcuiTimeOut` (non-zero); Host Client session timeout. **Ext. tools:** `Get-AdvancedSetting -Name UserVars.*TimeOut`; STIG scan.	Idle shell/DCUI/Host-Client sessions time out.	
SR/CR 2.6	Remote Session Termination	Confirm remote sessions can be terminated on demand and on inactivity timeout.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.7	Concurrent Session Control	Confirm concurrent-session limits or monitoring for privileged/engineering access.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.8	Auditable events	Remote **syslog**: `Syslog.global.logHost` set to the SIEM (ssl://); enable audit records (vSphere audit); persistent scratch/log location. **Test:** host events reach the SIEM. **Ext. tools:** `Get-AdvancedSetting -Name Syslog.global.logHost`; SIEM check.	Host events + audit records forwarded to remote syslog/SIEM.	
SR/CR 2.9	Audit Storage Capacity	Confirm audit/log storage is sized and rotated and alerts before overflow (or offloads to syslog/SIEM).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.10	Response to Audit Processing Failures	Confirm defined behavior on audit/log processing failure (alert; do not silently drop events).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.11	Timestamps	NTP configured & running: `esxcli system ntp get` / `Get-VMHostNtpServer` to authorized sources; NTP service policy = on. **Ext. tools:** `esxcli system ntp get`; Wireshark (NTP).	Accurate synced time; consistent event timestamps.	
SR/CR 2.12	Non-repudiation	Assess per objective: Determine whether a given human user took a particular action.	Met per SL-3 - verify on the product and capture evidence.	completeness
HDR 2.13	Physical Diagnostic/Test Interfaces (Host)	Assess the HDR-specific requirement per objective: Host device shall protect against unauthorized use of physical diagnostic and test interfaces.	Met per SL-3 - verify and capture evidence.	HDR completeness

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 3.1	Communication Integrity	Assess per objective: Protect integrity of transmitted information.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.2 (+ HDR 3.2)	Protection from malicious code	VIB acceptance level Partner/VMware-signed only (`esxcli software acceptance get` -> not CommunitySupported); **execInstalledOnly** (`VMkernel.Boot.execInstalledOnly = true`); Secure Boot enforces signed VIBs. **Ext. tools:** `esxcli software acceptance get`; STIG scan.	Only signed VIBs run; execInstalledOnly on; no CommunitySupported.	HDR-specific.
SR/CR 3.3	Security Functionality Verification	Verify security functions operate correctly (self-test / post-change re-verification / compliance scan).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.4 (+ HDR 3.14)	Software integrity & secure boot	**UEFI Secure Boot** + **TPM 2.0** host attestation (`esxcli system settings encryption get`, vCenter attestation status); signed image; verify `esxcli software vib signature verify`. **Ext. tools:** vCenter attestation view; STIG scan.	Secure Boot + TPM attestation pass; image integrity verified.	HDR-specific.
SR/CR 3.5	Input Validation	Assess per objective: Validate syntax and content of any process control input.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error Handling	Confirm errors are handled gracefully without leaking sensitive information or losing control.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.8	Session Integrity	Assess per objective: Protect session integrity, reject invalid session IDs.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.9	Protection of Audit Information	Confirm audit records are protected from unauthorized read/modify/delete (permissions + offload).	Met per SL-3 - verify on the product and capture evidence.	completeness
HDR 3.10	Support for updates	Patch via **vLCM** / baselines with signed images; verify version/patch level and a rollback (revert to prior image). **Ext. tools:** vLCM compliance; `esxcli software profile get`	Signed updates applied; rollback available.	HDR-specific.
HDR 3.11	Physical Tamper Resistance/Detection (Host)	Assess the HDR-specific requirement per objective: Host device shall resist and/or detect physical tampering.	Met per SL-3 - verify and capture evidence.	HDR completeness
HDR 3.12	Provisioning Supplier Roots of Trust (Host)	Assess the HDR-specific requirement per objective: Host device shall provision and protect product-supplier roots of trust used to validate firmware/identity.	Met per SL-3 - verify and capture evidence.	HDR completeness
HDR 3.13	Secure Boot (Host)	Assess the HDR-specific requirement per objective: Host device shall validate integrity of boot process.	Met per SL-3 - verify and capture evidence.	HDR completeness

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 4.1	Information confidentiality	**VM encryption** + **encrypted vMotion** (Required) via a KMS/native key provider; TLS for management. Verify `Get-VMHost | Get-View` encryption mode / vMotion encryption = required. **Ext. tools:** PowerCLI encryption status; STIG scan.	VM data + vMotion encrypted; management over TLS.	
SR/CR 4.2	Information Persistence	Confirm sensitive data can be purged/sanitized on decommission or re-use.	Met per SL-3 - verify on the product and capture evidence.	completeness

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 4.3	Use of cryptography	TLS 1.2/1.3 only (`UserVars.ESXiVPsDisabledProtocols` disables TLS1.0/1.1); strong ciphers; verify. **Ext. tools:** sslscan `:443`; STIG scan.	TLS 1.2/1.3 + strong ciphers; legacy TLS disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 5.1 / 5.2	Segmentation & boundary	**ESXi firewall** enabled with least services (`esxcli network firewall get` / `Get-VMHostFirewallException`); isolate mgmt/vMotion/storage VLANs; restrict allowed IP ranges per service. **Ext. tools:** Nmap (open services by segment); `esxcli network firewall ruleset list`	Firewall on with least services; networks segmented; sources restricted.	
SR/CR 5.3	General Purpose Person-to-Person Communication Restrictions	Assess per objective: Prevent general purpose messages from external users/systems.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 5.4	Application Partitioning	Assess per objective: Support partitioning of data, applications, services by criticality.	Met per SL-3 - verify on the product and capture evidence.	completeness

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 6.1 / 6.2	Audit accessibility & monitoring	Persistent logs + remote syslog to SIEM; vCenter events/alarms monitored; Skyline/health checks. Confirm logs are retained and reach the SIEM. **Ext. tools:** SIEM check; syslog listener.	Logs retained + forwarded; host/vCenter monitoring active.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 7.1 / 7.2	DoS protection & resource management	VM resource limits/shares/reservations and admission control prevent one VM starving the host; monitor host CPU/mem/datastore. **Ext. tools:** PowerCLI resource review; vCenter performance.	Resource controls prevent exhaustion; host stays available.	
SR/CR 7.3 / 7.4	Backup & recovery	Back up host config (`vim-cmd hostsvc/firmware/backup_config` / `Get-VMHostFirmware -BackupConfiguration`) and vCenter; test restore on a spare host. **Ext. tools:** Config backup export; lab restore.	Host config + vCenter backed up; restore tested.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Config settings baseline	Apply/verify the vSphere ESXi STIG / Security Config Guide via **Host Profiles** compliance or a PowerCLI audit script; document deviations. **Ext. tools:** STIG/SCAP; Host Profile compliance.	Host matches the STIG/SCG baseline; deviations documented.	
SR/CR 7.7	Least functionality	Disable SSH/ESXi Shell, **MOB** (`Config.HostAgent.plugins.solo.enableMob = false`), CIM, and unused services; Lockdown Mode; remove unneeded VIBs. **Ext. tools:** Nmap (open services); `Get-AdvancedSetting -Name Config.HostAgent.plugins.solo.enableMob`	Only required services enabled; MOB/SSH/Shell off; lockdown on.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 7.8	Component inventory	Capture version, hardware, and VIBs: `esxcli system version get`, `esxcli hardware platform get`, `esxcli software vib list`. **Ext. tools:** vCenter inventory; PowerCLI export.	Complete version/hardware/VIB inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
PowerCLI (VMware.PowerCLI)	Effective host security state (most rows)	`Get-VMHost | Get-AdvancedSetting -Name Security.*`; `Get-VMHostService`, `Get-VMHostFirewallException`, `Get-VIPermission`.	Read-only get; authorized account.
ESXCLI	Native host config query (many)	`esxcli system ntp get`, `esxcli software acceptance get`, `esxcli network firewall ruleset list`, `esxcli software vib list`.	Read-only.
DISA vSphere ESXi 8 STIG + vSphere Security Config Guide	Baseline compliance (all)	Evaluate the host against the STIG/SCG (STIG Viewer + PowerCLI audit scripts); primary pass/fail evidence.	Authorized; read-only audit.
SCAP / compliance scanner	Automated baseline check (all)	Run the vSphere SCAP content or a PowerCLI compliance script; export results.	Authorized scan account.
Nmap	Port/service exposure & segmentation (1.1, 1.13, 5.x, 7.7)	`nmap -sT -p 22,443,902,5989,8000 -T2` ; scan by segment; confirm 22 closed and mgmt isolated.	Tune timing on production.
sslscan / testssl.sh	TLS strength (4.3)	`sslscan :443`; confirm TLS1.2/1.3 + strong ciphers, no TLS1.0/1.1.	Read-only.
Wireshark / tcpdump	Comm integrity & NTP (2.11, 3.x)	SPAN/tap; confirm mgmt is TLS and inspect NTP/vMotion encryption.	Passive; SPAN/tap only.
Syslog server / SIEM	Audit forwarding & monitoring (2.8, 6.x)	Confirm host syslog + audit records arrive; trigger a test event.	Coordinate with SIEM team.
Nessus / OpenVAS	Known-CVE scan (3.x, general)	Authenticated scan for ESXi CVEs; cross-check VMware VMSA advisories.	ISOLATED/authorized.

Controlled - Project Use · Independent Assurance Authority · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.